

Análisis de intrusión con modelo diamante

Integrantes:

Aguilar Carrizales Miguel Ángel – 182318
Aznar Cuevas Luis Eduardo – 179880
Beltrán Reyna David – 183636
Gómez Arreguín Donaldo Demián – 179822
Morales Hernández Roberto Emiliano – 182377
Rosales Ramírez Josué Emiliano – 181760

Materia:

CNO V: Seguridad Informática

Profesor:

López, Servando

Grupo:

T46A

Contenido

Introducción.....	3
Objetivo general	4
Objetivos específicos	4
Parte 01. Comprensión del modelo	5
Parte 02. Análisis de evento (Modelo Diamante)	5
Escenario	5
Estructura por Evento.....	5
Preguntas	6
1. ¿Quién es el adversario en este escenario?.....	6
2. ¿Cuál es la capacidad utilizada?	6
3. ¿Qué tipo de infraestructura se emplea?	6
4. ¿Quién es la víctima primaria?.....	6
5. ¿Existe evidencia de movimiento lateral?	6
Parte 03. Relación con la Kill Chain.....	6
Parte 04. Hilos de actividad	7
Hilo 1 (Víctima 1)	7
Hilo 2 (Víctima 2)	7
Relación entre ambos (Pivoting)	8
Conclusión.....	8

Introducción

En esta actividad se analiza un escenario de malware utilizando ambos modelos. Primero se identifican los elementos principales del ataque: adversario, capacidad, infraestructura y víctima. Posteriormente, los eventos detectados se relacionan con las fases de la Kill Chain para comprender cómo se desarrolló la intrusión y cómo pudo propagarse dentro de la red.

El análisis de intrusiones es una parte fundamental de la ciberseguridad, ya que permite identificar cómo actúan los atacantes dentro de una red o sistema. Para comprender mejor estos incidentes, existen modelos como el Modelo Diamante y la Cyber Kill Chain, los cuales ayudan a organizar la información del ataque y relacionar sus diferentes etapas.

Objetivo general

Aplicar el Modelo de Diamante del Análisis de Intrusiones para identificar, estructurar y correlacionar eventos de ciberataques, relacionándolos con la Cyber Kill Chain para comprender el comportamiento del adversario.

Objetivos específicos

1. Identificar y clasificar los elementos del modelo: adversario, capacidad, infraestructura y víctima.
2. Analizar un incidente realista y descomponerlo en eventos de intrusión.
3. Relacionar los eventos con las fases de la Kill Chain y detectar patrones de ataque.

Parte 01. Comprensión del modelo

Elemento	Descripción	Ejemplo práctico
Adversario	Actor que realiza el ataque o la intrusión.	Grupo de ciberdelincuentes que distribuye malware.
Capacidad	Herramientas, técnicas y conocimientos utilizados en el ataque.	Malware con conexión a servidores C2.
Infraestructura	Recursos utilizados para ejecutar el ataque.	Dominios maliciosos, IP externas y servidores C2.
Víctima	Sistema, usuario u organización afectada.	Equipo de la empresa infectado con malware.

Parte 02. Análisis de evento (Modelo Diamante)

Escenario

Una organización detecta comportamiento anómalo en un equipo. El análisis revela:

1. La víctima detecta malware.
2. El malware contiene dominios de Comando y Control (C2).
3. Los dominios resuelven a direcciones IP externas.
4. Los logs muestran múltiples hosts conectándose a esas IP.
5. WHOIS/IP revela posible origen del atacante.

Estructura por Evento

Metacaracterística	Descripción del evento
Marca de tiempo	Momento en que el SOC detecta actividad anómala en la red.
Fase	Compromiso e instalación del malware.
Resultado	Equipo infectado y conexión establecida con C2.
Dirección	Comunicación saliente desde la red interna hacia IP externas.
Metodología	Phishing, ejecución de malware y comunicación remota.
Recursos	Malware, dominios C2, IP externas y herramientas de acceso remoto.

Preguntas

1. ¿Quién es el adversario en este escenario?

El adversario es un atacante externo o grupo APT que distribuye malware y controla equipos comprometidos mediante servidores C2.

2. ¿Cuál es la capacidad utilizada?

La capacidad utilizada incluye phishing, ejecución de malware, conexión remota con C2 y movimiento lateral dentro de la red.

3. ¿Qué tipo de infraestructura se emplea?

Se emplean dominios maliciosos, direcciones IP externas, servidores de Comando y Control (C2) y hosts comprometidos.

4. ¿Quién es la víctima primaria?

La víctima primaria es el equipo inicial de la organización donde se detectó el malware.

5. ¿Existe evidencia de movimiento lateral?

Sí. Los logs muestran múltiples hosts conectándose a las mismas IP externas, indicando posible propagación interna y pivoting.

Parte 03. Relación con la Kill Chain

Evento	Fase Kill Chain (versión clásica)	Justificación
Detección de malware	<i>No es una fase de la Kill Chain, es una detección.</i> La Kill Chain describe el ataque, no la defensa. Sin embargo, el malware	La detección ocurre después de la ejecución. Nos indica que el atacante ya superó fases previas.

	detectado suele corresponder a las fases de Instalación o C2 .	
Envío de phishing	Entrega (Delivery)	Esta es la fase donde el adversario transmite la carga útil (payload) a la víctima, a menudo mediante un correo electrónico con un enlace o archivo adjunto malicioso.
Conexión a C2	Comando y Control (C2)	El malware establece un canal de comunicación saliente para recibir instrucciones, descargar cargas útiles adicionales o exfiltrar datos. Es la fase de "mando".
Ejecución del malware	Explotación / Ejecución	Es el momento en que el código malicioso se activa en el sistema de la víctima. Tras una explotación exitosa (ej. macro malicioso), se ejecuta el <i>payload</i> .

Parte 04. Hilos de actividad

Hilo 1 (Víctima 1)

1. El atacante envía un correo phishing al administrador.
2. El administrador ejecuta el archivo malicioso.
3. El malware se instala en el equipo.
4. El host establece conexión con el servidor C2.
5. El atacante obtiene acceso remoto al sistema comprometido.

Hilo 2 (Víctima 2)

1. El atacante utiliza el equipo comprometido como proxy o pivote.
2. Se realizan conexiones internas hacia otros hosts.
3. Una segunda máquina recibe o descarga el malware.
4. El segundo host también establece conexión con el C2.

Relación entre ambos (Pivoting)

El atacante utiliza el primer equipo comprometido para desplazarse lateralmente dentro de la red y comprometer otros dispositivos. El host inicial funciona como puente entre el atacante externo y la segunda víctima.

Conclusión

El escenario representa un ataque tipo APT basado en phishing y malware con infraestructura C2. El Modelo Diamante permite identificar la relación entre adversario, capacidades, infraestructura y víctimas, mientras que la Cyber Kill Chain ayuda a clasificar cada fase del ataque y comprender la progresión de la intrusión.